Analisi di un hash di file con la Piramide del dolore

Scenario	Un'allerta segnalava un file sospetto. Dovevo capire se il suo hash fosse già noto come dannoso e poi collocare gli indicatori trovati sulla Piramide del dolore (Pyramid of Pain), per vedere quanto ciascuno farebbe male a un attaccante se lo bloccassi.
Il file è stato identificato come dannoso?	Sì. Ho cercato l'hash SHA-256 su VirusTotal e molti fornitori di sicurezza lo segnalano. I rilevamenti lo chiamano trojan, con nomi come Trojan.Flagpro e Fragtor. Flagpro è una famiglia di malware collegata a un gruppo di attaccanti chiamato BlackTech, quindi non è un malware comune qualunque.

Gli indicatori sulla piramide

Livello	Indicatore trovato	Quanto è difficile per l'attaccante cambiarlo	Cosa dà a chi difende
TTP	Command and control	Molto difficile. L'attaccante deve cambiare il proprio modo di lavorare.	Il rilevamento più duraturo, perché segue il comportamento e non un singolo campione.
Strumenti	Input capture (registrare ciò che l'utente digita)	Impegnativo. Serve uno strumento nuovo o una riscrittura.	Bloccarlo costringe a un vero sforzo, ma servono buone regole di rilevamento.
Artefatti di rete e host	Richieste HTTP usate per comunicare con l'attaccante	Fastidioso. Lo schema del traffico va ripensato.	Utile per regole che riconoscono la stessa famiglia anche dopo piccole modifiche.
Nomi di dominio	org.misecure.com	Semplice. Un dominio nuovo costa poco, ma va configurato.	Blocca la campagna in corso finché non cambiano.
Indirizzi IP	207.148.109.242	Facile. Un nuovo server si noleggia in fretta.	Utile nel breve periodo e invecchia presto.
Valori hash	MD5 287d612e29b71c90aa54947313810a25	Banale. Cambiando un byte si ottiene un hash nuovo.	Ferma solo questo preciso file.

La piramide usa il valore MD5 della scheda del laboratorio. La ricerca su VirusTotal l'ho fatta con l'hash SHA-256.

Cosa ne ho ricavato

L'hash era la cosa più facile da trovare ed è anche la meno utile da bloccare. Un attaccante può ricompilare lo stesso malware in un minuto e l'hash non corrisponde più. Ora capisco perché i team cercano di salire lungo la piramide. Rilevare il comportamento, per esempio un programma che registra i tasti premuti e poi contatta l'attaccante via HTTP, costa molto di più da evitare.

Si collega anche al case study sul ticket di allerta, dove il controllo dell'hash è stato uno dei passaggi che hanno portato all'escalation. Controllare l'hash è un buon primo passo, ma non mi fermerei lì.